RESEARCH WHITE PAPER / VERSION 1.0

Verified Compute Fabric

A proposed reference architecture for evidence-bound access and breach containment

ARCHITECTURAL THESIS

> A workload's authority should depend on authenticated evidence and a current, resource-specific policy. Compromise must not give the workload control over the boundaries that contain it.

Internet infrastructure | Software systems | Hardware trust

24 October 2026

STATUS: PROPOSED REFERENCE ARCHITECTURE

Research-backed design synthesis. No integrated implementation, benchmark result or certification is claimed. Technical requirements proposed here are distinguished from the capabilities established by the cited sources.

40 primary-source references • Two explicit deployment profiles

EXECUTIVE BRIEF

An architecture for bounded authority

Verified Compute Fabric is a proposed reference architecture that binds access to authenticated workload identity and approved execution evidence. Every protected operation is evaluated against a resource-specific policy. Authorization expires, and an enforcement point outside the compromised application can terminate access. The intended result is a measurable limit on the damage a successful intrusion can cause.

The proposal composes established security mechanisms with an explicit integration contract. NIST zero-trust guidance supplies the access-control model. IETF remote-attestation architecture supplies the evidence-processing roles. Software-supply-chain frameworks supply release evidence. These foundations support individual properties; they do not establish the security of the integrated design described here. [1, 3, 5]

CENTRAL DESIGN RULE

> A component must not be the sole authority deciding whether its own compromise should remove its privileges. Enforcement and recovery authority must remain outside the attacker capability covered by the selected assurance profile.

Deployment decision

The managed-host profile assumes a trustworthy host administrator and kernel. It contains application compromise using externally governed identity and resource-level authorization. The host-adversarial profile adds a supported confidential execution environment, an attested guest supervisor and an independent verifier. Its guarantees remain conditional on the hardware security model and the protected guest code.

Neither profile establishes that an authorized application is harmless. Access that is legitimately granted can still be abused. Data already disclosed cannot be recalled. Physical resource exhaustion and denial of service require independent availability engineering.

Implementation thesis

The recommended starting point is an immutable release pipeline with separated build authority, followed by independently enforced access leases. Hardware-backed attestation is introduced for workloads with a defined host-adversary requirement. Adoption proceeds through acceptance tests, with every unimplemented control recorded as an assurance gap.

Reading map	Location
Scope and trust boundaries; system architecture	Sections 1–3
Software, identity and attestation; runtime controls	Sections 4–7
Internet infrastructure and hardware	Sections 8–9
Interoperability, authorization contract and failure behavior	Sections 10–13
Recovery, deployment and validation	Sections 14–20
Primary-source references	References [1]–[40]

01 / SCOPE AND EVIDENCE

Research basis and threat model

This white paper is an architectural synthesis of publicly available standards, implementation documentation and academic research reviewed on 24 October 2026. It presents no integrated prototype measurements. Product documentation establishes supported mechanisms and stated assumptions; it does not independently validate a complete deployment. Cited research is used within the scope of the system studied.

“Verified” means that a specified verifier has authenticated evidence and evaluated named claims against a versioned policy. It is not a claim of formal verification, universal safety or regulatory certification. The name is descriptive within this paper and does not designate an industry standard.

Attacker capabilities

Threat	Required boundary	Residual exposure
Malicious package or application process	Independent identity issuance and resource enforcement	Permitted business operations and already accessible data
Compromised build job or developer credential	Isolated builders; release approval outside that job	Malicious approved source or compromised release authority
Stolen workload token	Short authorization leases; audience and sender binding	Compromised authorized caller or stolen binding key
Compromised host or provider administrator	Host-adversarial profile with protected guest enforcement	Hardware/firmware failures, guest compromise and availability
Compromised fabric authority	Scoped issuers; independent recovery and key rotation	Privileges within the compromised authority’s scope
Network partition or destructive attack	Explicit expiry behavior; independently recoverable state	Service interruption and transactions already committed

Assumptions that must be declared

Every deployment records the trusted computing base: hardware and firmware, the operating systems that can alter policy, identity issuers, release signers, attestation verifiers and recovery operators. It also identifies excluded attack classes, including any physical attacks or side channels outside the selected hardware model.

Administrative independence requires different compromise paths. Two services on one root-controlled host do not provide protection from that host. Separate accounts can still share a vulnerable recovery credential. A review must trace control of signing keys, network bypasses and backup deletion authority.

LOCAL REQUIREMENT LANGUAGE

> MUST and SHOULD in this paper express requirements of the proposed reference architecture. They do not amend the cited standards or imply certification by their authors.

02 / REFERENCE ARCHITECTURE

Control planes and trust boundaries

The architecture assigns responsibility to separate logical planes. A small installation may consolidate some services, but it must retain the claimed trust boundaries. NIST separates policy decisions from policy enforcement; its cloud-native guidance applies identity-based controls to distributed services. [1, 2]

Plane	Responsibilities	Candidate mechanisms
Release and evidence	Approve source and produce a versioned release manifest	SSDF; SLSA; in-toto; Cosign; SPDX; immutable registry
Identity and attestation	Authenticate a workload and appraise execution evidence	SPIFFE/SPIRE; RATS; EAT; Keylime or Trustee
Authorization	Issue scoped access leases using reviewed policy	OPA; an authorization service; a credential broker
Enforcement	Check the requested operation and close revoked access	Envoy or resource gateway; database authorization; guest supervisor; external network policy
Observation and revocation	Record decisions and propagate bounded revocation	Independent audit sink; signed events; durable policy epochs; acknowledgements
Recovery and governance	Restore trusted service and replace compromised authorities	Separate backup account; protected keys; controlled root rotation; clean rebuild

The table describes a proposed composition. Installing the named components does not automatically establish compatibility or the required security properties. An integration must define the identity mapping and evidence profile, then prove that every sensitive request traverses an effective enforcement point.

Resource-boundary enforcement

The protected resource trusts its gateway or native authorization mechanism. It does not accept an application's statement that admission previously succeeded. A backend endpoint that can be reached directly is a separate access path and must apply equivalent checks or be made unreachable.

Independent trust domains

Organizations operate local trust domains. Federation specifies accepted issuers and the exact resources they may address. Federation is nontransitive unless explicitly authorized: trusting one partner does not automatically trust that partner's other relationships. No universal internet identity provider or global blocking authority is required.

ARCHITECTURAL INVARIANT

> The authorization service can reduce or terminate a workload's authority without relying on that workload's cooperation. The selected assurance profile determines whether host cooperation may be assumed.

03 / SYSTEMIC PATTERNS

Evidence-bound admission and access

A deployment connects evidence to a specific running instance. Release approval, admission and per-operation authorization are separate decisions with separately scoped authorities. An approved artifact does not receive unrestricted access merely because its signature verifies.

Lifecycle stage	Required decision or binding
1. Release approval	Bind source revision, immutable artifact digest and configuration to an approved release manifest.
2. Restricted launch	Start without production secrets; permit only the bootstrap dependencies required for verification.
3. Evidence appraisal	Validate freshness and the selected execution profile; bind evidence to the instance's authenticated channel key.
4. Identity assignment	Map the verified instance to its approved logical workload and tenant. Reject self-selected identity claims.
5. Access lease	Authorize a bounded resource action with an audience, expiry and current policy epoch.
6. Enforcement and renewal	Evaluate requests and terminate expired sessions. Require acceptable evidence before renewal.
7. Revocation and recovery	Stop issuance, cut existing authority and rebuild from independently reapproved material.

Patterns that must persist across implementations

Immutable intent. A release manifest identifies the exact code and security-relevant configuration. Mutable image tags cannot identify the approved executable. Runtime-loaded plugins, mounted code and privileged initialization steps belong in the reviewed launch contract.

Explicit delegation. A workload acts for a specific tenant or authenticated user when the operation requires one. Service identity alone never supplies missing business authorization.

Finite authority. Every access grant has a defined lifetime and scope. Long-running sessions require an independently enforceable authorization deadline.

Independent containment. A revocation path must survive the compromise it is meant to contain. Host-root containment requires an off-host resource boundary or an applicable protected execution boundary.

Recoverable trust. The infrastructure needed to reestablish a trusted state must remain accessible when production identity and policy services are unavailable.

These patterns are proposed integration requirements. The supply-chain and attestation mechanisms used to implement them retain their own trust assumptions. [3, 7]

04 / SOFTWARE SUPPLY CHAIN

Approve the release that actually executes

Protected source and isolated builds

Use SSDF-aligned development controls and target SLSA v1.2 Build Level 3 for the build platform where feasible. SLSA's build requirements include protected provenance generation and build isolation. A project must assess the platform and its own responsibilities before claiming a level. An artifact signature alone does not establish SLSA conformance. [5, 13]

The proposed fabric separates build workers from production. Ephemeral workers receive only the inputs and publication authority needed for their job. They do not hold production deployment keys or the authority to approve their own output. Untrusted build steps must not receive a management host's Docker socket.

Verifiable release envelope

The release envelope MUST include the artifact digest, source revision and builder identity. It also identifies the dependency inventory and security-relevant launch configuration. in-toto can represent attestations about supply-chain steps. Cosign verification can check expected certificate identity and issuer while verifying artifact signatures. The release policy must pin those expectations to the intended repository and workflow. [6, 7]

Use SPDX to express the software bill of materials. The inventory supports vulnerability response and dependency identification; it is not evidence that every component is benign. Vulnerability exceptions require an owner and an expiration condition. The inventory should cover build-time and runtime dependencies where those inventories can be established. [40]

Admission binding and update security

The admission controller resolves immutable digests and checks that the approved configuration is the configuration supplied to the runtime. It rejects unauthorized mounts, altered entry points and unreviewed executable downloads. Reproducible builds can be an additional consistency check. Matching output does not establish the safety of the source that produced it.

Use TUF-style signed update metadata with separated roles, threshold authorization where appropriate and explicit expiry. Version checks must prevent an attacker from restoring a previously valid but revoked release. Emergency rollback is an authorized new decision with an audit record; it is not an exemption from anti-rollback controls. [8]

MALICIOUS BUT VALIDLY SIGNED SOFTWARE

> An approved release can contain a malicious dependency or a logic flaw. Runtime limits and resource authorization remain mandatory after every supply-chain check succeeds.

Engineering convention

Store the release manifest and its signatures separately from the application image. Production pulls the image by digest and independently verifies the release authorization. Signing keys used by release approval must not be available to application containers or ordinary build jobs.

05 / IDENTITY AND CREDENTIALS

Issue narrowly scoped, renewable authority

SPIFFE defines workload identifiers and identity documents. SPIRE can issue identities using node and workload attestation, including selectors derived from the local platform. A SPIRE identity is not, by itself, hardware evidence that the host is uncompromised. Its assurance depends on the trusted components used to make the identity assignment. [9, 10]

Logical identity and instance binding

Assign one logical identifier to a defined service role within a trust domain, with explicit tenant and environment boundaries. Record each instance separately. A permit binds that instance to its logical identity, release digest and evidence profile. The application cannot choose another tenant's identity by supplying an environment variable or a request header.

Human administration uses phishing-resistant authentication appropriate to the assurance requirement. NIST recognizes cryptographic mechanisms that provide phishing resistance. The proposal requires separate human and workload principals, with emergency administration subject to independent approval and audit. [39]

Credential brokering

Applications request a resource operation or a short-lived credential from a broker. The broker independently validates the workload identity and delegated user context. Credentials are scoped to the intended audience and action. The broker must not expose an unrestricted signing or decryption endpoint.

Where both issuer and resource support it, use certificate-bound OAuth access tokens or DPoP sender-constrained tokens. These mechanisms bind token use to possession of an associated key. Their benefit does not cover a compromised caller that can use that key or a provider endpoint that does not enforce the binding. [11, 12]

For an external API that accepts only a long-lived key, keep the key in a controlled broker. The application submits a typed operation to the broker, which enforces destination and action constraints. It must not act as an arbitrary HTTP relay. Requests have a tenant scope and usage ceiling. A provider credential that can bypass the broker requires its own containment plan.

Authority separation

Identity issuance answers who is calling. An access lease answers which operation is permitted. The application must also establish whose data the operation concerns. Database credentials must not turn a verified service identity into unrestricted access to every tenant.

PROPOSED INITIAL SETTINGS

> A pilot may begin with five-minute workload certificates and 60-second sensitive-operation leases. These are illustrative engineering parameters, not published best-practice requirements or measured safe limits. Renewals and session deadlines must be tested under load and during partitions.

06 / ATTESTATION

Bind evidence to an enforced launch contract

The RATS architecture separates an attester that produces evidence, a verifier that appraises it and a relying party that makes a decision. EAT provides a claims format that can be profiled for attestation. Neither supplies a universal definition of a safe workload. The relying party needs explicit claim semantics and trusted reference values. [3, 4]

Freshness and channel binding

A verifier challenges an instance with a fresh nonce. The resulting evidence must be tied to the intended audience and to a channel key generated inside the protected boundary when that protection is claimed. The broker verifies possession of that key. Copying a public report from another instance must not enable credential release.

A hardware-signed field containing an application-supplied digest is insufficient by itself. A measured, trusted supervisor must enforce the relationship between the digest and the loaded code. Otherwise a malicious host can quote an approved hash while executing different software. This binding requirement is a security inference from the separation between authenticated evidence and the truth of the claimed workload state.

Two implementation paths

Managed-host path. TPM-backed boot measurements and Linux IMA measurements can support integrity appraisal through Keylime. Coverage depends on what is measured and the trustworthiness of the measurement path. Measured files do not describe every in-memory action. A 2025 Keylime case study identified operational false positives and detection gaps under its tested conditions. Those findings motivate explicit coverage tests, not a claim that every present deployment shares the same defects. [21, 22]

Host-adversarial path. SEV-SNP or TDX supplies evidence for an applicable confidential guest. Trustee provides an attestation and key-broker architecture. Confidential Containers documents guest-enforced policy and Init-Data binding that can constrain what the host may request from a protected guest. The chosen integration must demonstrate that the attested supervisor enforces the approved image and configuration. [23–26]

Reference-value governance

Reference values originate from an approved release process. They must not be accepted merely because a host is currently running them. Maintain approved firmware and trusted-computing-base versions, with a deliberate patch transition window. Update verification collateral and retire vulnerable measurements when policy requires it.

CONTINUOUS EVALUATION HAS LIMITED COVERAGE

> Repeated appraisal can detect changes represented in its evidence. It cannot prove continuous benign execution. The architecture must publish what each evidence profile observes and which changes remain invisible.

07 / RUNTIME AND DATA

Contain execution and constrain business actions

Application isolation

The managed-host baseline runs services without unnecessary privilege. Apply non-root execution, restricted system calls and a mandatory-access-control profile. Avoid writable executable mounts. Set resource ceilings and remove unused capabilities. Docker's security model makes daemon access a sensitive administrative capability; application access to that authority is outside this baseline. [17]

For workloads that require an additional isolation boundary, evaluate gVisor or Firecracker against the actual system-call and operational requirements. gVisor provides a sandbox with its own security model. Firecracker provides a microVM architecture. Neither option automatically protects a workload from a malicious underlying host administrator. [18, 19]

Host-based eBPF policy and telemetry may provide useful enforcement within the managed-host profile. Cilium documents the trust boundaries of its deployment. A compromised host kernel cannot be assumed to enforce rules against itself. The host-adversarial profile therefore places essential resource decisions off-host or inside an applicable protected guest. [20]

Application and database authorization

A gateway must validate the requested action and its tenant context. Use narrow database roles and, where appropriate, row-level security. PostgreSQL superusers and roles with BYPASSRLS bypass row policies; table owners ordinarily bypass them unless FORCE ROW LEVEL SECURITY is applied. Application connections must not silently inherit those privileges. [37]

A tenant identifier must originate in authenticated delegation and survive every hop without caller-controlled substitution. A session variable that an attacker can set is not an adequate tenant boundary. Background jobs need explicit ownership of the records they process. Export and deletion operations require policy that reflects their data impact.

New software conventions

Use memory-safe languages for new security-sensitive components where ecosystem requirements permit. CISA and NSA recommend memory-safe development to address memory-safety vulnerabilities. Existing unsafe interfaces and foreign-function boundaries still require review. Memory safety does not resolve authorization flaws or malicious application logic. [14]

Treat AI-generated commands and retrieved content as untrusted inputs. A model may propose an action; a deterministic policy evaluates whether the action is authorized. Tool access is scoped to the authenticated task. An anomaly model must not grant itself privileges or modify the release policy.

CONTAINMENT LIMIT

> A compromised application may misuse data it is authorized to read. Operation budgets and resource-side controls can bound that exposure only to the extent that the business operation itself can be constrained.

08 / INTERNET INFRASTRUCTURE

Defend transport without creating a global authority

Routing integrity and source validation

Publish correct route-origin authorizations and deploy RPKI-based origin validation through a staged operational process. NIST provides deployment guidance, and RFC 6811 defines origin-validation behavior. Origin validation does not authenticate the complete BGP path. A route with no applicable authorization must not be casually treated as equivalent to an invalid route. [31, 32]

Deploy source-address validation consistent with BCP 38 and the network topology. This addresses spoofed source traffic. A botnet sending traffic from legitimate source addresses remains a threat, so source validation does not remove the need for attack absorption and service-level controls. [33]

DDoS mitigation and service continuity

Use upstream mitigation sized for the threat model. Validate the protected origin path and eliminate public bypasses to a supposedly shielded backend. Critical services require tested DNS recovery and independent administrative access. Geographic separation must be checked against shared upstream and account dependencies.

DOTS already defines an open signal channel for requesting DDoS mitigation. A fabric can integrate authenticated mitigation requests through participating providers. The proposed addition is a local authorization contract: each request is limited to resources the requester controls, carries an expiry and is subject to recipient-side validation. This paper does not propose a new universal blocking protocol. [34]

Workload connectivity

Mutually authenticated service connections establish peer identity. Resource policy still decides access. Restrict egress to required services and deny direct paths that evade the credential broker. A destination allowlist should address proxy relay behavior and DNS changes; merely permitting a broad shared hosting domain is not a complete data-exfiltration control.

The network control plane must retain authority over applicable enforcement devices when an application fails. A compromised host may require an independent switch, provider firewall or restricted DPU policy to interrupt its traffic. Traffic on ungoverned interfaces is outside that containment claim.

AVAILABILITY BOUNDARY

> Identity checks cannot restore a saturated physical link. An operator that controls power or scheduling can still deny service to a confidential guest. Availability requires capacity planning and independently exercised recovery routes.

Privacy convention

Federated decisions should disclose only the claims a partner needs. Avoid distributing raw device identifiers and internal deployment measurements without a purpose. Evidence retention and access policy are part of the trust agreement, not an implicit prerequisite for public internet access.

09 / HARDWARE

Make the protected boundary explicit

Hardware is selected to support a particular adversary model. A processor feature or security chip does not establish the safety of all software running on the machine. The deployment must identify what is protected and who can change that protection.

Mechanism	Intended role	Boundary that must be stated
Secure / measured boot and TPM	Verify boot policy and authenticate selected measurements	Does not by itself hide guest memory from a host operator
HSM or hardware-backed key	Protect selected key material against extraction	An authorized compromised caller may still invoke permitted key operations
SEV-SNP or TDX	Protect applicable confidential guests under a vendor threat model	Guest code, firmware state and attestation verification remain security dependencies
Restricted DPU / SmartNIC	Enforce designated network policy outside host control	Only traffic traversing the governed path is covered
CHERI capability architecture	Enforce capability-based bounds and compartment boundaries	Requires compatible software and a defined deployment profile

SEV-SNP and TDX are candidates for the host-adversarial profile, subject to supported platforms and verified launch semantics. The host can still deny scheduling or connectivity. Confidential execution also does not make vulnerable guest application code trustworthy. [23, 24]

NVIDIA documents a restricted BlueField mode that separates host privileges from DPU administration. An implementation must enable the relevant mode and isolate its management credentials. Ordinary deployment of a card does not establish that separation. The DPU's firmware and management environment become part of the trusted computing base. [27]

CHERI research provides hardware capabilities for memory access and software compartmentalization. It is an optional evaluation track in this architecture, with toolchain and application compatibility assessed per target. The baseline does not depend on universal CHERI availability or promise elimination of every memory-safety failure. [30]

Firmware is an operational dependency

Maintain authenticated firmware updates and independently usable recovery, consistent with NIST platform-firmware resiliency guidance. Hardware-backed claims must respond to security advisories. AMD's bulletin AMD-SB-3019 documents a microcode-signature vulnerability affecting relevant SEV-SNP protections and its mitigations. A verifier that ignores affected firmware can accept an obsolete security assumption. [28, 29]

10 / INTEROPERABILITY CONVENTIONS

Specify what each claim means

A deployable fabric needs a versioned implementation profile. The profile defines supported evidence and authorization formats, including failure behavior. Existing protocols remain unchanged. Profile-specific metadata must be clearly namespaced and validated; it must not silently reinterpret a standard field.

Convention	Proposed requirement
Identifiers and scope	Stable logical workload ID; separate instance ID; explicit environment and tenant; no wildcard federation by default
Artifact identity	Full content digest with an algorithm identifier; configuration and launch-policy digests where security-relevant
Evidence semantics	Named profile version, measured boundary, nonce, verification audience and reference-value policy version
Authorization	Resource and action, authenticated delegation, expiry, sender binding where supported, policy epoch
Signed objects	Explicit object type and issuer; approved algorithms and keys; reject unknown critical fields and ambiguous encodings
Revocation events	Unique event ID, scoped subject, durable monotonic epoch, effective time and acknowledgement state
Audit records	Decision ID, subject and release binding, policy version, outcome and expiry; sensitive values excluded

Serialization and signature discipline

Use the serialization and signature rules required by the selected existing envelope. A custom JSON object may use a defined canonicalization profile such as RFC 8785 when appropriate. The implementation must specify exact bytes and field handling. Do not mix incompatible canonicalization rules or infer algorithm choice from attacker-controlled data. [38]

Policy distribution

OPA supports signed bundles and retains its previous bundle when a new bundle fails verification. Its documentation notes that some JWT claims, including iat and iss, are not interpreted by bundle verification itself. A fabric must therefore implement and test its own required freshness and issuer-selection semantics. Bundle signature verification must be configured as mandatory; provisioning keys alone is not sufficient in every documented configuration. A valid signature does not establish that a bundle is the currently authorized policy. [15]

A signed monotonic policy epoch and explicit maximum validity establish when a cached decision expires. Each enforcement endpoint persists its accepted epoch and must resynchronize after state loss. Administrative rollback is expressed as a newly authorized version, with the reason recorded.

NO UNDEFINED TRUST SCORE

> An attestation result must expose the claims that passed and the profile used to evaluate them. Authorization must not rely on an unexplained aggregate score that obscures an unmet requirement.

11 / PROPOSED AUTHORIZATION CONTRACT

Separate release intent from runtime permission

The example defines an illustrative release-intent object. It is a proposal-specific schema with no out-of-the-box runtime support. Placeholder digests are intentionally invalid. A real implementation requires schema validation and a signed envelope with authorized issuers.

```
type: fabric.example/release-intent
schema_version: "0.1"
subject: "spiffe://example.org/prod/tenant-a/exporter"
release:
  manifest_digest: "sha256:<64-hex-digits>"
  image_digest: "sha256:<64-hex-digits>"
execution:
  profile: "managed-host-v1"
  launch_policy_digest: "sha256:<64-hex-digits>"
  evidence_max_age_seconds: 300
access:
  audience: "customer-export-gateway"
  resource: "tenant-a/customer-export"
  actions: ["create-approved-export"]
  delegation_required: true
  lease_max_seconds: 60
  session_deadline_required: true
failure:
  new_privileged_access: "deny"
  expired_lease: "terminate"
policy_epoch: 42
```

A release authority signs the intent. A verifier independently returns a signed appraisal result bound to a fresh challenge and the authenticated instance key. An authorization service then issues a distinct permit that identifies the instance, applicable policy and expiry. These objects have separate issuer roles; the application cannot create its own attestation result.

Proposed decision predicate

An operation is allowed only when the caller identity is authenticated, its required execution evidence remains acceptable, the release binding matches, the requested action and tenant are authorized, and the permit is current under the enforcement endpoint’s policy epoch. Sender-binding checks apply whenever the selected token profile requires them.

The managed-host example relies on the host for instance measurement and launch enforcement. Selecting a confidential-guest profile requires an attested guest supervisor and a verified binding to its enforced launch policy. Changing the profile string alone does not create hardware-backed protection.

12 / REVOCATION

Bound access after a revocation decision

Certificate lifetime, access-token lifetime and an established session's lifetime are separate quantities. A short-lived certificate does not automatically terminate an existing TLS session. The fabric MUST impose an authorization deadline on sensitive sessions and have a tested way to close them.

Revocation transaction

A scoped revocation commits a new policy epoch and stops new permits for the affected subject. Enforcement endpoints receive the event and acknowledge application. Resource gateways close affected sessions, and an independent network control may quarantine the instance. Unacknowledged paths remain visible until their prior permits expire.

The target set includes every gateway and resource replica that can authorize the operation. A signed event is not evidence that enforcement occurred. The audit record must distinguish event creation, receipt and effective denial. Compromised issuers require rotation of their trust relationship; revoking one workload identity is insufficient.

Isolated issuers MUST lose the ability to mint permits under a retired epoch. A consistent authorization store or bounded issuer lease must enforce this condition. A revocation bound cannot be claimed while disconnected issuers can indefinitely renew the affected authority.

Conditional containment bound

```
T_stop <= max over paths p of min(D_p + A_p, L_p + S_p + C_p)
```

T_stop is elapsed time from committed revocation until all covered paths reject the affected authority. D_p is event-delivery delay. A_p is application delay, including session closure. L_p bounds the remaining authorization horizon on that path, including permits that can still be issued under unexpired issuer authority. S_p bounds clock uncertainty, and C_p bounds expiry-to-closure delay. An unavailable push path has an unbounded D_p.

This is a proposed analytical bound, not an empirical result. It assumes complete path coverage, trustworthy deadline enforcement and a bounded lifetime for every issuer's authority. L_p must include any remaining issuer lease and downstream permit lifetime; an issuer with unbounded renewal makes that expiry bound unavailable. Detection and decision time are additional. An uncovered backend path or a compromised enforcement boundary invalidates the bound. Data already read and completed transactions are not reversed.

Illustrative pilot objectives

A pilot can test a maximum 60-second sensitive-operation lease and a 99th-percentile event-application target below 10 seconds. These values are proposed test objectives, not performance claims. Capacity testing must include reconnect bursts and simultaneous credential renewal.

ACTIVE STREAMS AND TRANSACTIONS

> Define how a revoked long-running export or database operation is cancelled. Disconnecting a client may not undo a transaction already accepted by the backend. Cancellation behavior and partial-result handling belong in the resource contract.

13 / FAILURE SEMANTICS

Preserve policy during outages

An access system is incomplete until it specifies behavior during partial failure. Availability choices must be recorded per resource. Silent fail-open behavior is prohibited for privileged operations in this proposal.

Failure condition	Required behavior
Identity issuer or attestation verifier unavailable	Do not issue new elevated authority. Existing bounded permissions may continue only until their previously authorized deadline.
Policy service unreachable	Use an authenticated cached policy only within its approved validity. Deny new privileged access when that validity expires.
Policy signature fails or epoch decreases	Reject the update. Retain the last acceptable policy only while it remains valid; raise an operator-visible incident.
Revocation channel partitioned	Expire permissions locally and terminate covered sessions. Do not silently extend authorization to preserve service.
Clock integrity or persisted epoch lost	Enter a restricted recovery state. Reestablish trusted time and policy state before granting new sensitive authority.
Audit destination unavailable	Use protected bounded buffering; explicitly deny operations whose policy requires durable audit before execution.
Enforcement controller compromised	Revoke its authority from an independent boundary and activate the clean recovery process.

Local decisions and bounded caching

Policy evaluation may run near a protected resource to avoid a synchronous global service dependency. The local evaluator must authenticate its configuration and respect lease deadlines. Envoy's external-authorization filter provides an enforcement integration point; deployments must set failure behavior explicitly and test every protected route. Shadow-mode evaluation is not an enforcement guarantee. [16]

Bootstrap without circular dependencies

Keep a restricted path to the trust anchors and verification services needed for enrollment. Recovery must not depend exclusively on the identity issuer being recovered. Document the independent mechanism used to restore that issuer, including protected administrative credentials and the network path used during a production outage.

Automated containment is scoped by service or tenant. A single noisy detector must not receive unrestricted power to disable the whole fleet. Emergency overrides require a named operator and a bounded validity period. The override cannot silently remove the audit trail.

14 / GOVERNANCE AND RECOVERY

Recover the authority to trust a system

Separation of administrative powers

The release owner approves application intent. The security authority approves evidence profiles and resource policy. Operational staff execute approved deployments. Small teams may hold multiple roles, but high-impact root changes require an independent approval path. Separate signing keys express these roles even when some administrative work is shared.

Every authority has a documented scope and a revocation procedure. Protect root and recovery keys outside ordinary production workloads. Hardware-backed keys are useful where supported, but permitted signing or decryption operations still require authorization. Restrict management-plane access and record emergency use in an independent audit destination.

Recoverable evidence and state

CISA recommends protected backups and tested restoration in ransomware preparation. The fabric maintains independently accessible backups for essential application data and the configuration needed to reconstruct trust services. A backup process that production administrators can erase through the same credential does not meet the intended independence requirement. [35]

Object-lock mechanisms can preserve retained object versions. S3 documents distinct governance and compliance retention behavior. Retention of object bytes does not establish that the data is clean, that every dependency was backed up or that the decryption key remains available. Protect retention configuration and key lifecycle independently. [36]

Recovery sequence

Establish a clean recovery control plane with reviewed trust anchors. Suspend compromised issuing authority and preserve incident evidence. Reassess the approved release set, including the builder and signer. Deploy a clean instance and reissue only the permissions it requires. Restore a selected data checkpoint after checking application consistency and signs of contamination.

Rejoining production requires the same admission checks as a new instance. Do not exempt a recovery deployment from policy because the service is urgent. A separately approved emergency profile may reduce functionality while retaining the minimum containment boundary.

RESTORE TEST AS A SECURITY TEST

> An acceptance exercise must rebuild from a state in which the production identity service and ordinary administrator account are unavailable. It must verify application correctness and key availability, not merely successful file retrieval.

Operational ownership

Assign an owner to each evidence profile and every trust root. Record supported hardware and software versions. Establish an advisory response process for changes to that trusted computing base. Publish the maximum accepted age of verification collateral and the exception process for a failed patch rollout.

15 / DEPLOYMENT PROFILES

Declare the protection actually deployed

Property	Managed-host profile	Host-adversarial profile
Trusted host	Host administrator, kernel and hypervisor are trusted	Host operator is outside selected confidentiality/integrity assumptions
Execution boundary	Hardened container or suitable sandbox / microVM	Supported confidential guest with trusted guest supervisor
Instance evidence	Trusted platform selectors; optional TPM / IMA appraisal	Verified TEE evidence bound to enforced guest launch policy
Credential release	Broker validates identity and approved release	Off-host broker additionally validates the confidential execution profile
Resource enforcement	Off-workload gateways and native resource authorization	Off-host enforcement or applicable protected guest enforcement
Host compromise claim	No host-root resistance claimed	Only properties covered by the selected hardware and guest threat model
Availability	Independent redundancy and recovery required	Independent redundancy and recovery required

The profile names are proposed conventions. They must be accompanied by a versioned conformance statement listing actual controls and exclusions. Hardware attestation should not be presented as an optional cosmetic badge attached to an otherwise unchanged managed-host deployment.

Control placement determines the claim

A policy proxy running beside the application can protect against a constrained application process if the isolation boundary holds. Host root may control both. A remote database gateway can still deny that host access if its credentials and administration are independently protected. A confidential guest may protect internal keys from its host, subject to the hardware model and the correctness of the guest components. [17, 23, 24]

Integration surface

SPIRE, OPA and a selected gateway can provide major building blocks, but the full admission contract requires implementation-specific integration. Trustee and Confidential Containers provide an attestation path for supported environments. The document's instance permits, policy epochs and end-to-end revocation guarantees must still be implemented or mapped to equivalent supported controls and tested. [9, 15, 25, 26]

CONFORMANCE DISCLOSURE

> A deployment must identify controls that are enforced, controls that are observed only and controls that are absent. No broad "verified" label may conceal a missing workload binding or an unprotected direct resource path.

16 / PRACTICAL REFERENCE DEPLOYMENT

A Docker and Coolify adoption path

The managed-host profile can guide an incremental Docker-based deployment without requiring a migration to Kubernetes. This section is a proposed operating pattern. It does not claim that stock Coolify implements the complete contract or that a particular live environment has been inspected.

Boundary	Proposed placement and responsibility
Build environment	Separate ephemeral worker; produces a signed release envelope; no production secrets
Deployment authority	Restricted management service verifies release approval and deploys exact digests
Application hosts	Supported Docker configuration; restricted workloads; no application-held daemon authority
Identity and policy services	Protected service boundary; reviewed SPIRE registrations and versioned policy
Sensitive resource gateway	Independent host or account where needed; validates permits and prevents backend bypass
Audit and recovery	Independent destination and credentials; immutable retention where appropriate; exercised restore

Preserve supported operations

Use supported deployment interfaces and external verification hooks. Any additional adapter needs tests and an upgrade-compatibility policy. Avoid presenting an unsupported modification to a management product as an established security feature. When a required enforcement hook does not exist, document the gap and choose a supported enforcement point.

Management-plane exception

A deployment manager may legitimately require broad Docker control. Treat it as privileged infrastructure with a restricted administrative path. It is not an ordinary application container. The goal is to prevent untrusted jobs and applications from inheriting that authority. Docker's daemon security model makes this separation consequential. [17]

First protected business operation

Select one sensitive operation, such as exporting a tenant's customer records. Put the export behind an independent gateway. Bind the request to a verified service and authenticated tenant authorization. Deny direct database access to the exporter except where its role genuinely requires it. Apply a finite export lease and test forced cancellation.

Expand only after the isolated operation passes the revocation and recovery exercises. Adding hardware attestation later requires a compatible execution environment and a new evidence profile. It must not be represented as a configuration switch that secures an arbitrary existing VPS.

17 / ADOPTION AND ECONOMICS

Advance through evidence-based gates

Rollout should be gated by demonstrated properties. Calendar deadlines do not establish assurance. Each stage publishes its residual risk and the evidence required to proceed.

Stage	Exit evidence
Baseline inventory	Known workloads and sensitive resources; documented administrators; all direct backend paths identified
Release integrity	Exact-digest deployment; controlled signer and builder; negative tests reject altered artifacts and unauthorized configuration
Bounded authorization	Scoped service identities; brokered credentials; resource-side enforcement; successful tenant-boundary tests
Revocation and recovery	Measured session termination under partition; independently restored service after loss of production administration
Hardware-backed profile	Verified launch binding on supported hardware; rejected stale or mismatched evidence; firmware transition and recovery tests
Federation	Explicit partner issuer scope; privacy agreement; bilateral revocation and compromise exercises

Operating-cost model

The principal costs include engineering ownership of policy and evidence profiles, plus the availability burden of the identity and verification services. Other cost drivers are signature and attestation throughput, certificate renewal load, audit retention and duplicate recovery capacity. Hardware procurement is relevant only to profiles that require it.

An evaluation should measure CPU and memory overhead alongside application throughput. Report request latency at the median and tail. Include cold start, burst enrollment and mass revocation. Do not extrapolate a single microbenchmark into a claim about fleet-wide security or application performance.

Avoiding a security control-plane bottleneck

Replicate issuance and verification services where the security model permits. Keep resource enforcement capable of applying a valid local policy without a synchronous central call on every operation. Local caching must retain the expiry and anti-rollback requirements. A resilient implementation still denies privileged access after its authorized cache validity ends.

Procurement convention

Require each provider or component owner to state supported claim semantics and the tested failure modes. “Supports attestation” is insufficient without a documented binding to the application that receives the secret. “Signed images” is insufficient without approved signer selection and verification of the image actually launched.

INVESTMENT PRIORITY

> Fund release verification and enforceable access leases first. Adopt the host-adversarial profile when a documented threat model requires protection from host administration and the team can operate its additional trust dependencies.

18 / VALIDATION

Acceptance tests must attempt to break the claim

The proposed architecture requires negative tests and fault injection. Each result records the component versions and selected profile. A passed test is evidence for the tested condition, not proof that all attack paths have been exhausted.

Test	Expected acceptance evidence
Approved signer, wrong repository or builder	Release admission denies the artifact and identifies the failed policy condition
Valid image, modified launch configuration	Unauthorized entry point or executable mount is rejected
Replayed attestation or substituted instance key	Broker refuses release; challenge and channel binding are verified
Stale firmware evidence or retired measurement	Verifier rejects new elevated access under the current profile
Tenant substitution and overbroad data role	Resource denies cross-tenant reads and privileged database bypass
Stolen sender-constrained token on another key	Resource rejects token use without the required proof of possession
Direct backend connection or egress relay	Bypass is blocked or independently subject to equivalent authorization
Revocation during a long-running export	Covered streams close within the declared bound; partial outputs are recorded
Partitioned revocation / policy service	Permissions expire locally; no unapproved lease extension occurs
Old signed policy after a restart	Durable epoch prevents rollback; unsynchronized instances cannot elevate access
Host-root control in managed-host profile	Report explicitly marks host-root resistance as outside the claim
Host interference in confidential profile	Selected protected secrets remain unavailable in tested cases; denial of service remains possible
Compromised issuer or inaccessible production account	Independent root rotation and restore procedure completes and is audited

Execution discipline

Run destructive tests in an authorized environment with representative data and recovery capacity. Record unsuccessful attack attempts and any successful bypass. Repeat the relevant test set after changes to the runtime, firmware or trusted policy. A detector alert without effective denial does not satisfy an enforcement test.

19 / MEASUREMENT AND LIMITATIONS

Evaluate bounded harm and operational correctness

Metrics with security meaning

Report the number of sensitive operations that have complete enforcement coverage and the number with unresolved bypasses. Measure actual credential exposure and the maximum data accessible under one workload's authorized role. Those quantities define the scope of a successful compromise. A count of installed products does not establish that scope.

Record time to detect an incident separately from time to revoke after the decision. For revocation, publish the slowest tested covered path and the tail distribution. Track expiry enforcement during outages, recovery-point loss and time to restore trusted service. Publish false-denial rates and the operational consequences of policy errors.

Known assurance gaps

Attestation coverage remains bounded by the evidence collected. The Keylime case study illustrates the practical difficulty of evaluating runtime integrity in changing systems. Heterogeneous TEEs and runtime stacks also require explicit interpretation of measurements. A common token format does not make every vendor's evidence semantically equivalent. [4, 22]

An authorized malicious release can operate inside its permitted scope. Colluding administrators or compromised roots may authorize harmful policy. A confidential guest can contain vulnerable code. Network partitions make immediate globally consistent revocation unavailable without sacrificing access on isolated paths. The proposal resolves that last tradeoff by requiring finite local authorization deadlines for sensitive operations.

Research and engineering agenda

Workload binding. Develop independently reviewable tests connecting protected instance keys to the exact executable and launch policy. Include late-loaded code and state migration.

Revocation semantics. Validate maximum session duration across proxies and databases. Explore policy-epoch recovery after state loss without permitting rollback or permanent denial.

Policy correctness. Test whether generated least-privilege policies preserve intended business operations while excluding prohibited actions. AI-produced policies require deterministic validation and accountable approval.

Interoperability. Publish a minimal profile specification with reference test vectors. Require each implementation to disclose unsupported claims and any downgrade behavior.

CONCLUSION

> A Verified Compute Fabric is credible only when each access claim can be traced to authenticated evidence, an accountable policy decision and an enforceable boundary. Its central deliverable is a tested limit on authority after compromise. This paper proposes the contract and validation program needed to establish that limit; it does not claim the limit has already been demonstrated.

20 / REQUIREMENT TRACEABILITY

Map every promise to an observable control

The identifiers below are proposed conformance requirements for this paper. Supporting references establish relevant mechanisms. The integrated guarantees require the acceptance evidence described here.

ID / requirement	Implementation evidence	Foundation
R-01 / Declare the trusted boundary	Profile identifies host assumptions and complete trusted computing base	NIST zero trust; RATS [1, 3]
R-02 / Bind approval to execution	Approved artifact and launch configuration match the running instance	SLSA; in-toto; Cosign [5–7]
R-03 / Authenticate workload identity	Registration and instance mapping reject caller-controlled impersonation	SPIFFE / SPIRE [9, 10]
R-04 / Bind evidence to the receiver	Fresh attestation and channel key are tied to enforced launch state	RATS; Trustee; guest policy [3, 25, 26]
R-05 / Constrain each operation	Resource checks audience, tenant and action with no ungoverned bypass	NIST cloud-native access; Envoy [2, 16]
R-06 / Limit credential use	Lease scope and supported sender binding are enforced by the resource	OAuth mTLS / DPoP [11, 12]
R-07 / Enforce policy freshness	Signed version, validity and durable epoch reject rollback	TUF; OPA mechanisms [8, 15]
R-08 / Terminate revoked authority	All covered paths enforce the tested lease and session deadline	Proposed integration requirement
R-09 / State outage behavior	Partition tests demonstrate explicit denial and recovery behavior	Proposed integration requirement
R-10 / Protect and recover roots	Independent recovery restores service after loss of production authority	Firmware resilience; recovery guidance [28, 35]
R-11 / Maintain the hardware profile	Firmware and collateral policy excludes unacceptable TCB states	Vendor attestation and advisories [23, 24, 29]
R-12 / Publish limitations	Conformance report includes residual risks and unimplemented controls	Proposed governance requirement

A conformance report includes the release set, profile versions and test results. It identifies the parties authorized to change each trust anchor. Claims are limited to the tested system configuration and named threat model. Certification or independent evaluation would require a separate process.

PRIMARY SOURCES / 01–10

References

Sources consulted 24 October 2026. Titles are linked to the originating publisher. Maintained documentation can change; implementation reviews should retain the exact revision used.

[1] **NIST.** Zero Trust Architecture. SP 800-207, August 2020.

[2] **NIST.** A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments. SP 800-207A, September 2023.

[3] **IETF.** Remote ATtestation procedureS (RATS) Architecture. RFC 9334, January 2023. Informational.

[4] **IETF.** The Entity Attestation Token (EAT). RFC 9711, April 2025. Standards Track.

[5] **SLSA.** Version 1.2: Build requirements. Approved specification. Build-track assurance requirements.

[6] **Sigstore.** Verifying Signatures. Cosign documentation. Artifact identity and issuer verification.

[7] **S. Torres-Arias et al.** in-toto: Providing farm-to-table guarantees for bits and bytes. 28th USENIX Security Symposium, 2019, pp. 1393–1410.

[8] **The Update Framework.** The Update Framework specification. Maintained specification. Signed metadata and update security.

[9] **SPIFFE Project.** SPIRE Concepts. Node attestation, workload attestation and registration.

[10] **SPIFFE Project.** SPIFFE Concepts. Workload identifiers, trust domains and identity documents.

PRIMARY SOURCES / 11–20

References

Sources consulted 24 October 2026. Titles are linked to the originating publisher. Maintained documentation can change; implementation reviews should retain the exact revision used.

[11] **IETF.** OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens. RFC 8705, February 2020. Standards Track.

[12] **IETF.** OAuth 2.0 Demonstrating Proof of Possession (DPoP). RFC 9449, September 2023. Standards Track.

[13] **NIST.** Secure Software Development Framework (SSDF) Version 1.1. SP 800-218, February 2022.

[14] **CISA and NSA.** Memory Safe Languages: Reducing Vulnerabilities in Modern Software Development. Cybersecurity information sheet, June 2025.

[15] **Open Policy Agent.** Bundles. Policy distribution and bundle-signature verification documentation.

[16] **Envoy Project.** External Authorization. HTTP authorization-filter documentation and enforcement configuration.

[17] **Docker.** Docker Engine security. Daemon authority and container-security documentation.

[18] **gVisor Project.** Security Model. Sandbox threat model and isolation boundaries.

[19] **A. Agache et al.** Firecracker: Lightweight Virtualization for Serverless Applications. 17th USENIX NSDI, 2020, pp. 419–434.

[20] **Cilium Project.** Threat Model. Security assumptions and cluster trust boundaries.

PRIMARY SOURCES / 21–30

References

Sources consulted 24 October 2026. Titles are linked to the originating publisher. Maintained documentation can change; implementation reviews should retain the exact revision used.

[21] **Keylime Project.** IMA / Integrity Measurement Architecture. Runtime-integrity documentation, version 7.11.0.

[22] **M. Ruffin et al.** Towards Continuous Integrity Attestation and Its Challenges in Practice: A Case Study of Keylime. IEEE/IFIP DSN, 2025. Research paper.

[23] **AMD / J. Powell.** AMD SEV-SNP Attestation: Establishing Trust in Guests. Linux Security Summit Europe, September 2022.

[24] **Intel.** Intel Trust Domain Extensions (Intel TDX). Architecture and developer overview.

[25] **Confidential Containers Project.** Attestation Architecture. Trustee, attestation service and key-broker architecture.

[26] **Confidential Containers Project.** Securing Your Workload. Runtime selection, guest policy and attested Init-Data.

[27] **NVIDIA.** BlueField Modes of Operation. DOCA 3.5 archive. DPU and restricted host modes.

[28] **NIST.** Platform Firmware Resiliency Guidelines. SP 800-193, May 2018.

[29] **AMD.** AMD SEV Confidential Computing Vulnerability. Security bulletin covering CVE-2024-56161 and mitigations.

[30] **University of Cambridge.** CHERI: Capability Hardware Enhanced RISC Instructions. Research overview and capability-system design.

PRIMARY SOURCES / 31–40

References

Sources consulted 24 October 2026. Titles are linked to the originating publisher. Maintained documentation can change; implementation reviews should retain the exact revision used.

[31] **NIST.** Protecting the Integrity of Internet Routing: Border Gateway Protocol (BGP) Route Origin Validation. SP 1800-14, June 2019.

[32] **IETF.** BGP Prefix Origin Validation. RFC 6811, January 2013. Standards Track.

[33] **IETF.** Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing. RFC 2827 / BCP 38, May 2000.

[34] **IETF.** Distributed Denial-of-Service Open Threat Signaling (DOTS) Signal Channel Specification. RFC 9132, September 2021. Standards Track.

[35] **CISA.** StopRansomware Guide. Prevention, incident response and recovery guidance.

[36] **Amazon Web Services.** Locking objects with Object Lock. S3 retention modes and write-once-read-many controls.

[37] **PostgreSQL Global Development Group.** Row Security Policies. PostgreSQL documentation, current edition consulted.

[38] **IETF.** JSON Canonicalization Scheme (JCS). RFC 8785, June 2020. Informational.

[39] **NIST.** Digital Identity Guidelines: Authentication and Authenticator Management. SP 800-63B-4, 2025.

[40] **SPDX Project.** SPDX Overview. Software bill of materials and specification overview.